CASE VAULT

SYSTEM OPERATIONS MANUAL

A practical guide to running, navigating, and operating the current React / FastAPI / MongoDB implementation. This edition reflects the 10 MiB PDF upload rule.

Document control

ITEM	CURRENT VALUE
Edition	20 October 2026
Code baseline	main commit 6b23654
Stack	React + Vite; FastAPI + Beanie/Motor; MongoDB + GridFS
Source attachment	CASE_VAULT_SOURCE_CODE.zip (89 tracked files plus manifest)
Excluded	Local .env secrets, installed packages, Git history, live database records

Contents

SECTION	SUBJECT
01-02	System overview; setup and sign-in
03-04	Navigation and permissions; operating workflows
05-06	Integrity verification; validation and error handling
07-08	Database fields; API reference
09-10	Code map; tests, limits, and demonstration

This is an implementation manual. The project documentation PDF is a separate reference; the software behavior described here is checked against the current source code.

01

System overview

Case Vault is a React frontend connected to a FastAPI backend. Metadata is stored in MongoDB through Beanie and Motor, PDF bytes are stored in GridFS, and actions are recorded in audit_transactions. The frontend hides unauthorized controls; the backend checks permissions again on every protected route.

RECORD	PURPOSE
Case	Numbered investigation record with a type, creator, submission date, and review status.
Evidence	Titled item associated with exactly one active case.
Evidence version	One PDF file, upload SHA-256 baseline, upload time, and retained tamper flag. Replacements add versions.
Tag	Reusable user-created label attached to cases through case_tags.
Audit transaction	Actor, timestamp, action, target IDs, and safe metadata.
User / role	Account activation, assigned role, and database-backed permissions.

Case status (open, under review, closed) tracks workflow. Integrity status describes the latest on-demand hash comparison for a specific evidence version. They are independent.

02

Setup and sign-in

01 Install Python 3.12, a compatible Node.js release, and a MongoDB replica set that supports transactions. MongoDB Atlas can be used.

02 From the repository root, use the existing venv or create one, then run: .\venv\Scripts\python.exe -m pip install -r requirements.txt

03 Create a private .env from .env.example with MONGO_URI, DB_NAME, and JWT_SECRET. Keep the connection string and secret out of source control.

04 For a fresh database, run: .\venv\Scripts\python.exe -m app.services.seed_service. For an existing database, stop API writes, back it up, then run: .\venv\Scripts\python.exe -m app.services.migration_service.

05 Start the API: .\venv\Scripts\python.exe -m uvicorn app.main:app --reload --host 127.0.0.1 --port 8000. Wait for Application startup complete, then inspect /docs.

06 In a second PowerShell window, cd case-vault-frontend; run npm.cmd ci once and npm.cmd run dev. Open the printed Vite URL, normally http://localhost:5173.

07 Sign in with a seeded or administrator-created account. Fresh seeding creates admin@casevault.org with a temporary password defined in seed_service.py; change it immediately.

SETTING	MEANING
MONGO_URI	Private MongoDB connection string.
DB_NAME	Database selected by the backend.
JWT_SECRET	Private token-signing secret.

SETUP AND SIGN-IN / CONTINUED

CORS_ORIGINS	Optional comma-separated frontend origins.
VITE_API_BASE_URL	Frontend API base; development default is /api, proxied to port 8000.
TEST_MONGO_URI	Isolated transaction-capable test database URI; never use production.

The browser uses an in-memory router. Use tabs and buttons to navigate; typing a page path or refreshing returns to the app entry flow. Backend permission checks still protect direct API requests.

03

Navigation and permissions

DESTINATION	ADMIN	ANALYST	REVIEWER	ENTRY
Case Vault logo	Admin home	Welcome	Welcome	Click logo
Case Library	Yes	Yes	Yes	Top tab
Case Detail	Yes	Yes	Yes	Open a case
Create Case	Yes	Yes	No	New Case
Secure Submission	Yes	Yes	No	Tab / Add Evidence
Status overview	Yes	Yes	Yes	Top tab
Password settings	Yes	Yes	Yes	Key icon
Activity Ledger	Admin home	No	No	Admin home

The AuditTrail.jsx component remains in source, but /audit redirects to access control; it is not an independent reachable tab. Without a selected case, Case Detail directs users to the library. LOG OUT ends the active session and revokes the presented token.

Built-in role actions

ACTION	ADMIN	ANALYST	REVIEWER
View active cases, evidence, versions, tags	Yes	Yes	Yes
Create case; upload or replace PDF	Yes	Yes	No
Change case review status	Yes	No	Yes
Create tag	Yes	Yes	No
Assign / remove tag on case	Yes	Yes	Yes
Delete tag globally	Yes	No	No
Verify and download evidence version	Yes	Yes	Yes
Archive case or evidence	Yes	No	No

NAVIGATION AND PERMISSIONS / CONTINUED

Manage users and view all audit activity	Yes	No	No
Change own password	Yes	Yes	Yes

Custom roles may exist. Inspect the Permission Matrix or GET /users/me/access for effective grants. Archive actions also require the built-in admin role at runtime.

04

Operator workflows

Create and inspect a case

01 Administrator or analyst: choose New Case in the Case Library. Enter a unique Case Number (2-50 characters) and a free-text Case Type (2-100 characters).

02 Submit the form. The backend records creator, submission timestamp, initial open status, and a case_created audit action.

03 Search the library by number, type, creator, or tag; filter by status. Open a row for Case Detail. Reviewers can view and change workflow status but cannot create cases.

GET /cases also accepts status, case_type, q (literal case-number substring), analyst_id (creator ID), and inclusive submitted_from / submitted_to dates. Date boundaries cover whole UTC days. The library's text and status controls filter its loaded list in the frontend.

Upload first evidence PDF

01 Create or open an active case. Administrator or analyst: open Secure Submission or Add Evidence in Case Detail.

02 Select Associated Case. Options show case_number - case_type; the value submitted is the database case ID. The selection is required.

03 Enter Evidence Title (2-255 characters), choose Evidence Classification (2-50 characters), and optionally add description (up to 2,000), source device (up to 200), and notes (up to 2,000).

04 Select a nonempty PDF of at most 10 MiB (10,485,760 bytes). The backend checks name, MIME, and actual PDF structure with pypdf. Renaming another file .pdf does not make it valid. This is not malware scanning.

05 Submit. GridFS stores the received bytes and SHA-256 becomes version 1's upload baseline. Evidence, version metadata, and audit entry commit together. Upload success does not imply a later integrity check occurred.

UI CLASSIFICATION EXAMPLES	BACKEND RULE
Device Extraction Report; System Log Report; Network Analysis Report	Evidence type is 2-50 characters; labels are not restricted to this list.
Mobile Artifact Report; Incident Documentation; Other Forensic Document	Use a consistent organizational naming practice.

Replace and inspect versions

01 Administrator or analyst: select Replace PDF for active evidence. The replacement uses the same 10 MiB and PDF-structure checks.

OPERATOR WORKFLOWS / CONTINUED

02 A replacement gets the next version number, a new GridFS file, and its own SHA-256 baseline. Older versions remain available for download and verification.

03 Metadata writes are transactional and version numbers have a unique compound index. GridFS writes happen before the metadata transaction; definite failures trigger cleanup of the new file when possible. Crashes or uncertain commits may require reconciliation.

Tags, status, accounts, and archive

Tags are user-created and reusable. Admins and analysts can create unique names of 2-50 characters. All three built-in roles can assign and remove case tags. Removing one assignment preserves the tag for other cases; admins can delete a tag globally. Tag changes are audit logged.

Admins and reviewers can change case workflow status to open, under review, or closed. Analysts cannot change it. Admin home shows account counts, presence, case counts, Permission Matrix, Registered Users, System Roles, latest on-demand integrity result, and Activity Ledger. Add User requires name, email, temporary password, and role. The account detail control supports role changes and activation/deactivation. Account deletion is unavailable.

Every user can change their own password through the key icon (8-128 characters). Only admins can archive cases or evidence. Archive sets deleted_at and retains metadata, versions, and files. Ordinary endpoints block archived items; separate admin API endpoints can inspect archived metadata. The UI has no archive browser or restore action.

05

Evidence integrity

Select Verify for the current or an older version in Case Detail. Each request reads stored GridFS bytes, recomputes SHA-256, compares it with that version's upload baseline, and records the result. Verification is on demand; there is no scheduled monitoring.

VISIBLE RESULT	MEANING
Not checked	No completed comparison has been recorded for the version.
Intact	Stored bytes matched the baseline at the displayed check time.
Mismatch detected	The computed hash differed from the upload baseline.
Check failed	Comparison could not finish, for example because stored bytes were unavailable.

The historical is_tamper_flagged boolean is separate from the latest result. A mismatch sets it true; a later intact comparison does not automatically clear it. An unreadable file is an error, not confirmed tampering.

Completed comparisons create evidence_verified audit entries with intact true or false. Storage-read errors create evidence_verification_failed; the first mismatch may also create tamper_flagged. Admin home shows the latest on-demand check and links to its case when available. The current verification action uses GET even though it writes audit entries; do not prefetch or auto-refresh it.

06

Validation and error handling

RESULT	OPERATOR RESPONSE

VALIDATION AND ERROR HANDLING / CONTINUED

Cannot reach API	Check backend startup, port 8000, Vite proxy or API base, and MongoDB connectivity.
400 Bad Request	Correct password or rejected PDF name, MIME, or content; read response detail.
401 Unauthorized	Token missing, expired, revoked, or session lease ended; sign in again.
403 Forbidden	Account deactivated or permission missing; inspect assigned role.
404 Not Found	Target absent, archived, or not part of requested parent record.
409 Conflict	Duplicate number/tag/assignment or an already active login.
413 Too Large	PDF exceeds 10 MiB (10,485,760 bytes); reduce it before upload.
422 Validation	Required field, type, length, or date range invalid; inspect field details.
503 Verify	Stored file unreadable; record Check failed, not a hash mismatch.
500 / 502	Capture Network response and backend log; check MongoDB and migration state.

The frontend displays Philippine time (Asia/Manila, PHT); stored timestamps and case search date bounds use UTC. /health indicates FastAPI startup, but does not check every database query.

One active login is allowed per account. A JWT lasts at most eight hours. Authenticated requests and the frontend’s one-minute heartbeat renew a three-minute server lease. Closing a tab stops renewals but does not reliably call logout. Successful logout revokes the token and releases the session.

07

Database fields

COLLECTION	KEY FIELDS / MEANING
users	role_id, name, email, hashed_password, is_active, deleted_at, created_at, updated_at.
roles / permissions / role_permissions	Role names, permission codes, and links.
cases	case_number, case_type, status, created_by, submission_date, created_at, updated_at, deleted_at.
evidence	case_id, submitted_by, evidence_type, title, optional description/source_device/notes, current_version_id, next_version_no, deleted_at.
evidence_versions	evidence_id, uploaded_by, version_no, file_name, file_type, file_hash, storage_path, is_tamper_flagged, uploaded_at.
GridFS	fs.files and fs.chunks hold PDF bytes; storage_path identifies a stored file.
tags / case_tags	Unique tag names; case/tag links, assigned_by, assigned_at.
audit_transactions	actor_user_id, case_id, evidence_id, action, safe metadata, occurred_at.

DATABASE FIELDS / CONTINUED

active_sessions / revoked_tokens	Token fingerprint and lease timestamps; revoked token hash and expiry.

MongoDB IDs are serialized as strings. case_number is the human-facing reference; case_id links records. intact is one comparison outcome; is_tamper_flagged is retained version state. Password hashes and PDF bytes are not returned by normal metadata endpoints.

08

API reference

Except for login and health, business routes require a bearer token. Access below lists an additional permission or built-in role restriction. /docs provides complete schemas while the backend is running.

METHOD / PATH	PURPOSE	ACCESS
POST /auth/login	Sign in	Valid account
POST /auth/heartbeat; /auth/logout	Renew / end session	Signed-in
GET /users/me; /users/me/access	Own profile / grants	Signed-in
PATCH /users/me/password	Change own password	Signed-in
GET/POST /users; PATCH /users/{id}	List/create/update users	user:manage
GET /roles	Role/permission matrix	user:manage
GET /cases; GET /cases/{id}	Search/view active cases	case:view
POST /cases	Create case	case:create
PATCH /cases/{id}	Change review status	case:update_status
DELETE /cases/{id}	Archive case	Admin + case:delete
GET /cases/deleted[/{id}]	Inspect archived case	Admin + case:delete
POST /evidence	Upload first PDF	evidence:upload
GET /evidence/by-case/{id}; /evidence/{id}	List/view evidence	evidence:view
POST /evidence/{id}/versions	Upload replacement	evidence:upload
GET /evidence/{id}/versions[/{version_id}]	List/view versions	evidence:view
GET /evidence/{id}/versions/{version_id}/download	Download stored PDF	evidence:view
GET /evidence/{id}/versions/{version_id}/verification-status	Read latest check	evidence:view
GET /evidence/{id}/versions/{version_id}/verify	Run and record check	evidence:view
DELETE /evidence/{id}	Archive evidence	Admin + evidence:delete
GET /evidence/deleted[/{id}]	Inspect archive	Admin + evidence:delete

API REFERENCE / CONTINUED

GET /tags; GET /cases/{id}/tags	Read tags	case:view
POST /tags	Create tag	tag:create; reviewer denied
POST /cases/{id}/tags	Assign tag	tag:assign
DELETE /cases/{id}/tags/{tag_id}	Remove association	case:view
DELETE /tags/{tag_id}	Delete global tag	Admin + tag:create
GET /audit; /audit/integrity/latest; /audit/stream	Audit / latest / live	user:manage
GET /health	Basic health response	Public

No route hard-deletes stored evidence files, restores archived items, edits a stored baseline hash, deletes accounts, or schedules integrity checks.

09

Code map and variables

SOURCE AREA	RESPONSIBILITY
app/main.py	FastAPI app, CORS and validation, database startup, router mounting.
app/core/config.py; database.py	Settings, MongoDB client, Beanie initialization, migration/index checks.
app/core/security.py; password_policy.py	Password hashing, JWTs, password rules.
app/dependencies/auth.py	Current user and permission dependencies.
app/models/; app/schemas/	Beanie collections and Pydantic request/response validation.
app/routers/	Auth, user, role, case, evidence, tag, and audit endpoints.
app/services/storage_service.py; audit_service.py	GridFS and SHA-256 operations; audit creation.
app/services/session_service.py	Token fingerprints, lease claim/check/release, online IDs.
app/services/seed_service.py; migration_service.py	Built-in grants, first admin, explicit migration and indexes.
frontend/src/App.jsx	In-memory navigation and protected routes.
frontend/src/auth/; src/lib/api.js	Login, logout, heartbeat, bearer token, API errors, PHT dates.
frontend/src/layouts/; components/	Tabs, header controls, and Philippine clock.

CODE MAP AND VARIABLES / CONTINUED

frontend/src/pages/	Login, Welcome, CaseLibrary, CreateCase, CaseDetail, SecureSubmission, AccessControl, PasswordSettings, AuditTrail.
tests/; scripts/	Unit/integration tests and database connection probes.

Important frontend state includes user.permissions (visible actions), caseId (selected case), file (selected PDF), checks (version results), latestIntegrity (admin summary), and TOKEN_KEY (tab session token). The embedded ZIP contains the exact tracked source bytes, SOURCE_MANIFEST.tsv, and CODE_INDEX.tsv.

10

Tests, limits, and demonstration

Checks reported for the current code change: backend pytest -q had 26 passed and 1 skipped; the skipped integration test needs TEST_MONGO_URI for an isolated transaction-capable test replica set. Frontend lint and build passed. These checks do not certify current Atlas connectivity or production behavior.

The system checks PDF structure and stores upload SHA-256 baselines, then verifies stored bytes on request. It does not scan for malware, continuously monitor files, use an HSM or blockchain, or delete accounts. GridFS byte writes cannot participate in metadata transactions; crashes or uncertain commits can require orphan-file reconciliation.

Safe demonstration with test data

01 Sign in as analyst; create a case and upload a valid PDF no larger than 10 MiB. Show that the baseline exists but the version reads Not checked before verification.

02 Sign in as reviewer; open the case, change its review status, assign a tag, and select Verify. An unchanged file should show Intact at the check time.

03 Sign in as administrator; inspect Permission Matrix, Activity Ledger, latest integrity result, and account controls. Archive only test records and show that normal endpoints hide them while admin archive endpoints retain metadata.

04 Demonstrate a rejected upload with a non-PDF file renamed .pdf or a file exceeding 10 MiB. Never alter real evidence to simulate tampering.